Vulnerability Assessment: **Unrestricted File Upload**
Project 4: Web Application Security Assessment
Week 3: Secure SDLC and Code Review

Vulnerability Information

- **Vulnerability Type:** Unrestricted File Upload
- **Risk Level:** Critical
- **OWASP Category:** A05:2021 – Security Misconfiguration
- **Location:** /upload.php, lines 1–8

Vulnerable Code Analysis

- Low

```
1  $target_path  = DVWA_WEB_PAGE_TO_ROOT . "hackable/uploads/";
2  $target_path .= basename( $_FILES[ 'uploaded' ][ 'name' ] );
```

- Medium

```php
if( ( $uploaded_type == "image/jpeg" || $uploaded_type == "image/png" ) &&
    ( $uploaded_size < 100000 ) ) {
```

- high

```php
$uploaded_ext  = substr( $uploaded_name, strrpos( $uploaded_name, '.' ) + 1);
$uploaded_size = $_FILES[ 'uploaded' ][ 'size' ];
$uploaded_tmp  = $_FILES[ 'uploaded' ][ 'tmp_name' ];

// Is it an image?
if( ( strtolower( $uploaded_ext ) == "jpg" || strtolower( $uploaded_ext ) == "jpeg" || strtolower( $uploaded_ext ) == "png" ) &&
    ( $uploaded_size < 100000 ) &&
    getimagesize( $uploaded_tmp ) ) {
```

User-controlled filenames and MIME types are accepted without proper validation or sanitization, enabling the upload of malicious scripts or files disguised as images.

Secure Code Screenshot:

```php
$uploaded_ext = strtolower(pathinfo($_FILES['uploaded']['name'], PATHINFO_EXTENSION));
$uploaded_size = $_FILES['uploaded']['size'];
$uploaded_tmp = $_FILES['uploaded']['tmp_name'];

$allowed_ext = ['jpg', 'jpeg', 'png'];

if (in_array($uploaded_ext, $allowed_ext) &&
    $uploaded_size < 100000 &&
    getimagesize($uploaded_tmp)) {

    $new_name = bin2hex(random_bytes(8)) . '.' . $uploaded_ext;
    $upload_dir = '/var/www/uploads/';
    move_uploaded_file($uploaded_tmp, $upload_dir . $new_name);
}
```

Mitigations Applied:

- Enforced strict extension and MIME type whitelisting
- Validated file content using getimagesize()
- Randomized filenames to prevent path disclosure
- Moved uploaded files outside the web root directory

Recommendations for Development Team

Immediate Actions:

1. Implement file extension and MIME type whitelisting with content verification.
2. Store uploaded files outside the web root with secure permissions.
3. Rename uploaded files with random values and strip original extensions.

References

- **OWASP Cheat Sheet:** File Upload Cheat Sheet
- **CWE Reference:** CWE-434: Unrestricted Upload of File with Dangerous Type
- **Best Practice:** Enforce secure upload handling and perform server-side validation for all user files.